Email Security

Email Security

- E-mail is one of the most widely used network services
  - One of the old killer applications of the Internet
- Normally message contents not secured
  - Can be read/modified either in transit or at destination by the attacker
- E-mail service is like postcard service
  - just pick it and read it

Email Security Enhancements

- confidentiality
  - protection from disclosure
- authentication
  - of sender of message
- message integrity
  - protection from modification
- non-repudiation of origin
  - protection from denial by sender

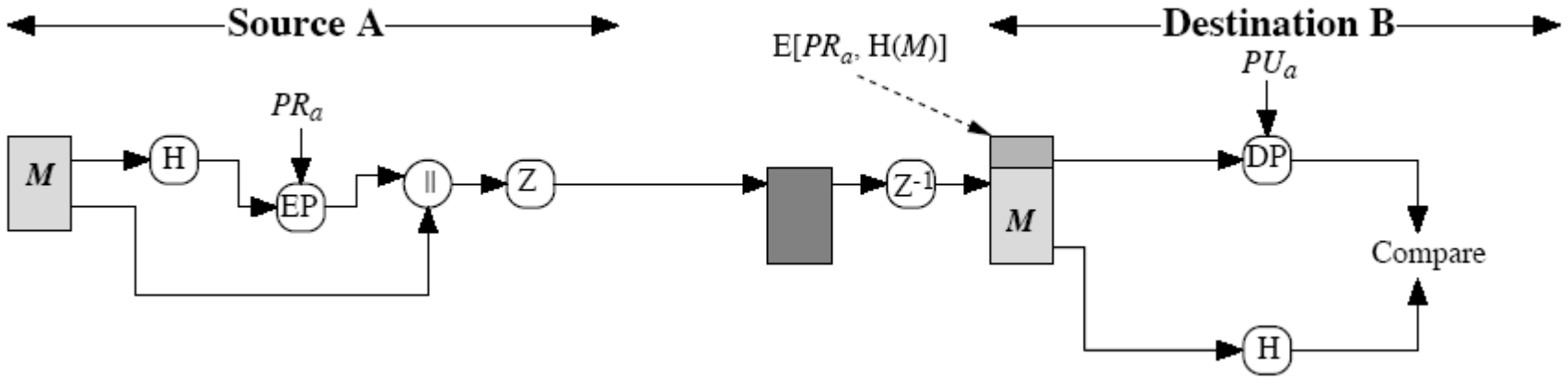
Pretty Good Privacy (PGP)

- Widely used secure e-mail software
  - originally a file encryption/decryption facility
- Developed by Phil Zimmermann
- Best available crypto algorithms are employed
- Available on several platforms with source code
- Originally free, now commercial versions exist
- Not controlled by a standardization body
  - although there are RFCs

PGP Mechanisms

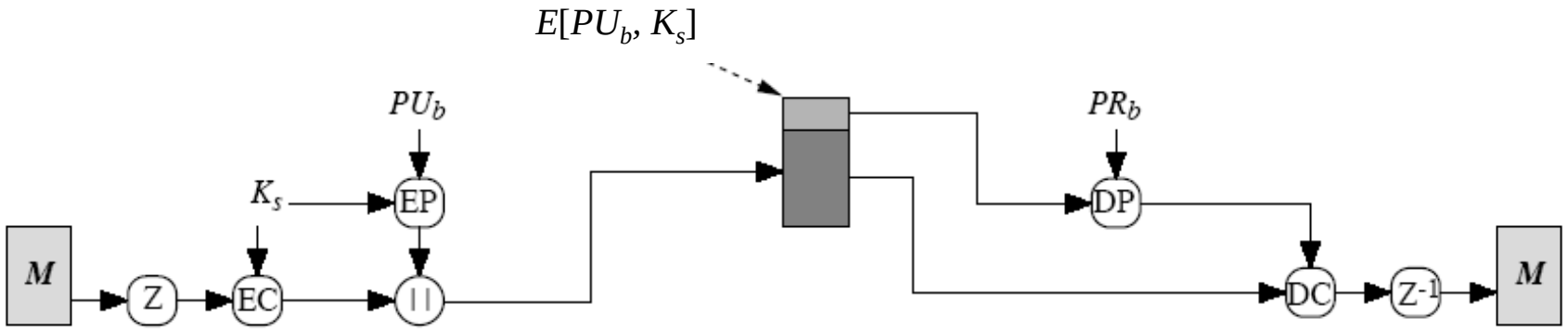
- Digital Signatures (and consequently message authentication and integrity)
  - RSA, DSS, and others
- Message Encryption
  - CAST, IDEA, 3DES, AES, etc. (all at least 128 bits)
  - symmetric keys are used once and encrypted using RSA or ElGamal
- Compression using ZIP
- Radix-64 conversion (to ASCII)
  - for e-mail compatibility

PGP Operation – Digital Signatures



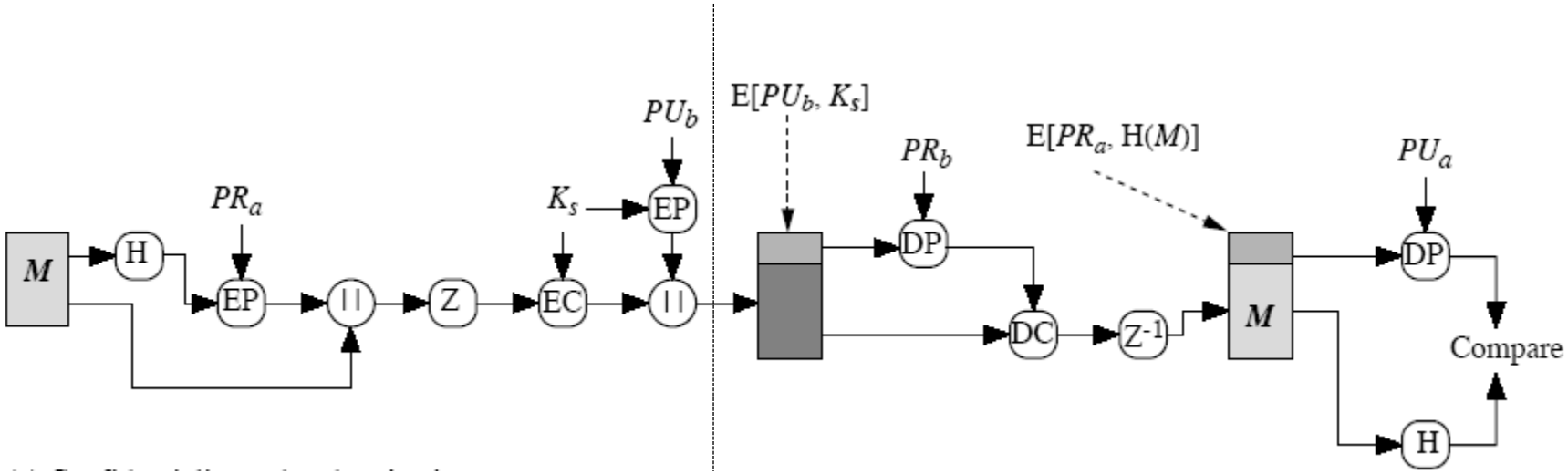
- Classical application of public key crypto
  - This figure is actually for RSA
  - for DSA refer to previous lectures
- Z is zip function
- radix-64 conversion is done after zip at sender, before Z^{-1} at receiver
  - may be done only for signature or for the whole message

PGP Operation – Confidentiality



- One-time session key, K_s
  - generated at random
  - encrypted using a public key cryptosystem, EP
    - RSA or ElGamal
- Message is compressed before encryption
  - This is the default case

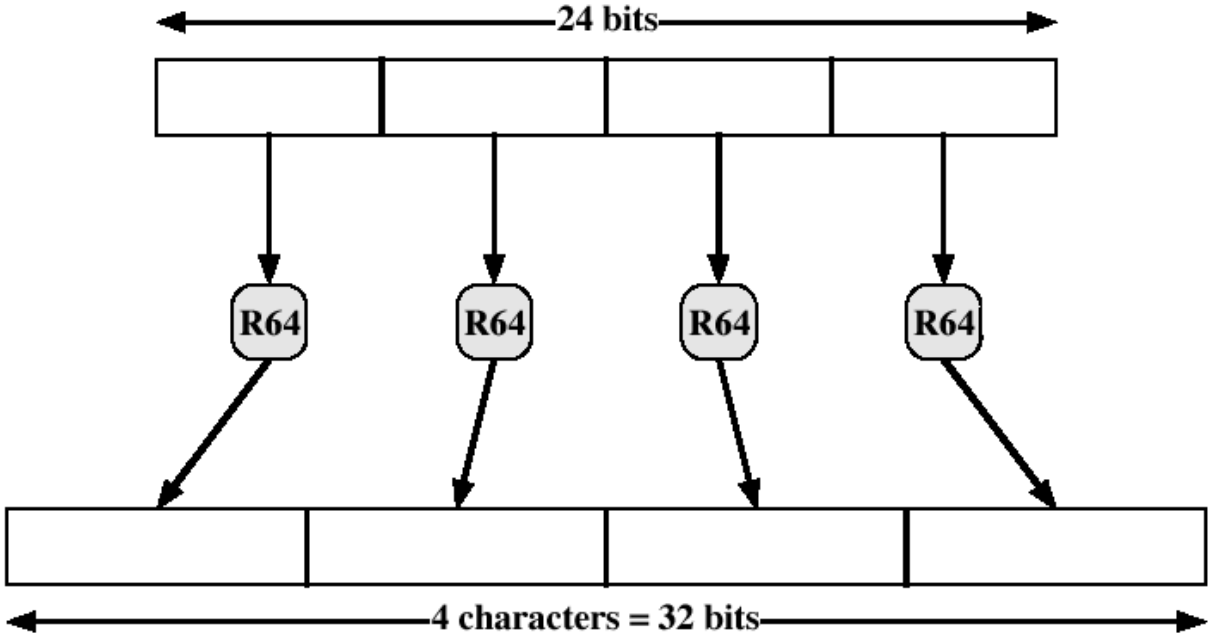
PGP Operation – Confidentiality and Authentication



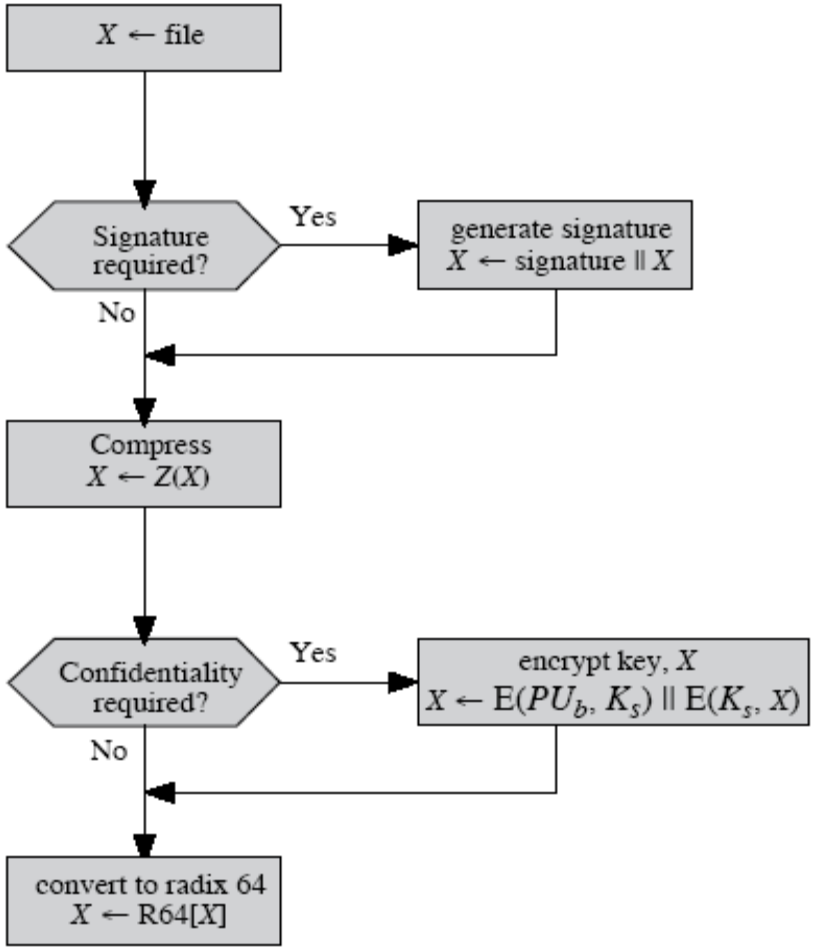
- uses both services on same message
  - create signature and attach to message
  - compress and encrypt both message & signature
  - attach encrypted session key
  - radix-64 conversion is for everything at the end

PGP Operation – radix-64 conversion

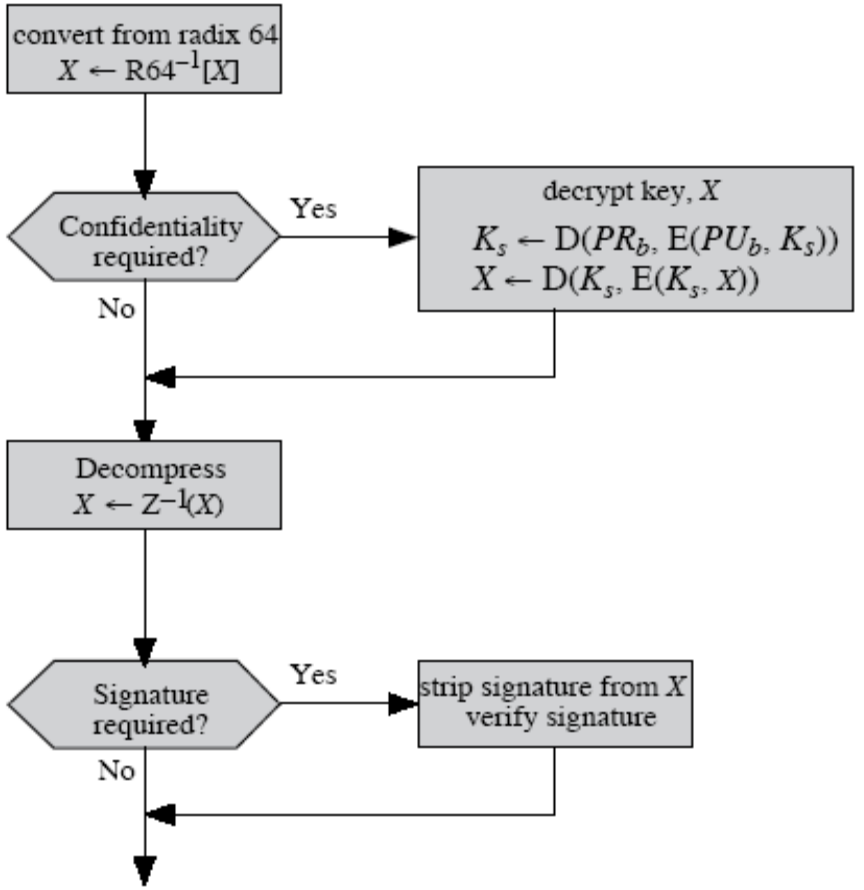
- Encrypted text and signatures create binary output
- however email was designed only for text
  - hence PGP must encode raw binary data into printable ASCII characters
- uses radix-64 algorithm (See CS408 notes)
  - maps 3 bytes to 4 printable chars



PGP Operation – Summary



(a) Generic Transmission Diagram (from A)



(b) Generic Reception Diagram (to B)

PGP Key ID concept

- since a user may have many public/private keys in use, there is a need to identify which is actually used to encrypt the session key in a message
  - PGP uses a key identifier which is least significant 64-bits of the public key
  - uniqueness?
    - very likely, at least for a particular user ID (e-mail address)
- Key IDs are used in signatures too
  - key ID for the public key corresponding to the private key used for signature
- Key IDs are sent together with messages

PGP Key Rings

- each PGP user has a pair of keyrings to store public and private keys
  - public-key ring contains all the public-keys of other PGP users known to this user

Public Key Ring

Timestamp	Key ID*	Public Key	Owner Trust	User ID*	Key Legitimacy	Signature(s)	Signature Trust(s)
• • •	• • •	• • •	• • •	• • •	• • •	• • •	• • •
T_i	$PU_i \bmod 2^{64}$	PU_i	trust_flag_i	User i	trust_flag_i		
• • •	• • •	• • •	• • •	• • •	• • •	• • •	• • •

* Key ID, Used ID combination uniquely identifies a key

PGP Key Rings

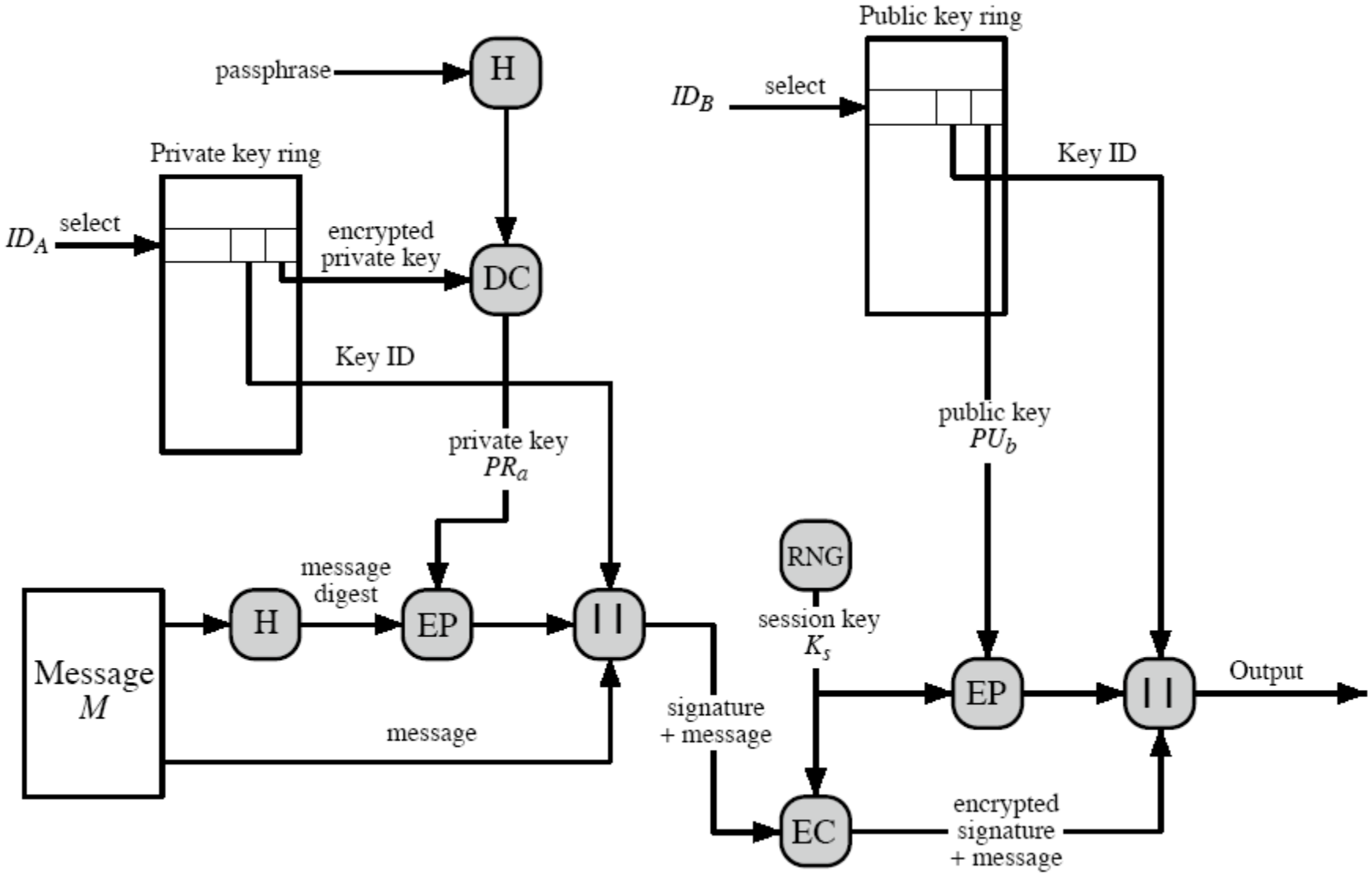
- private-key ring contains the public/private key pair(s) for this user,
- private keys are encrypted using a key derived from a hashed passphrase

Private Key Ring

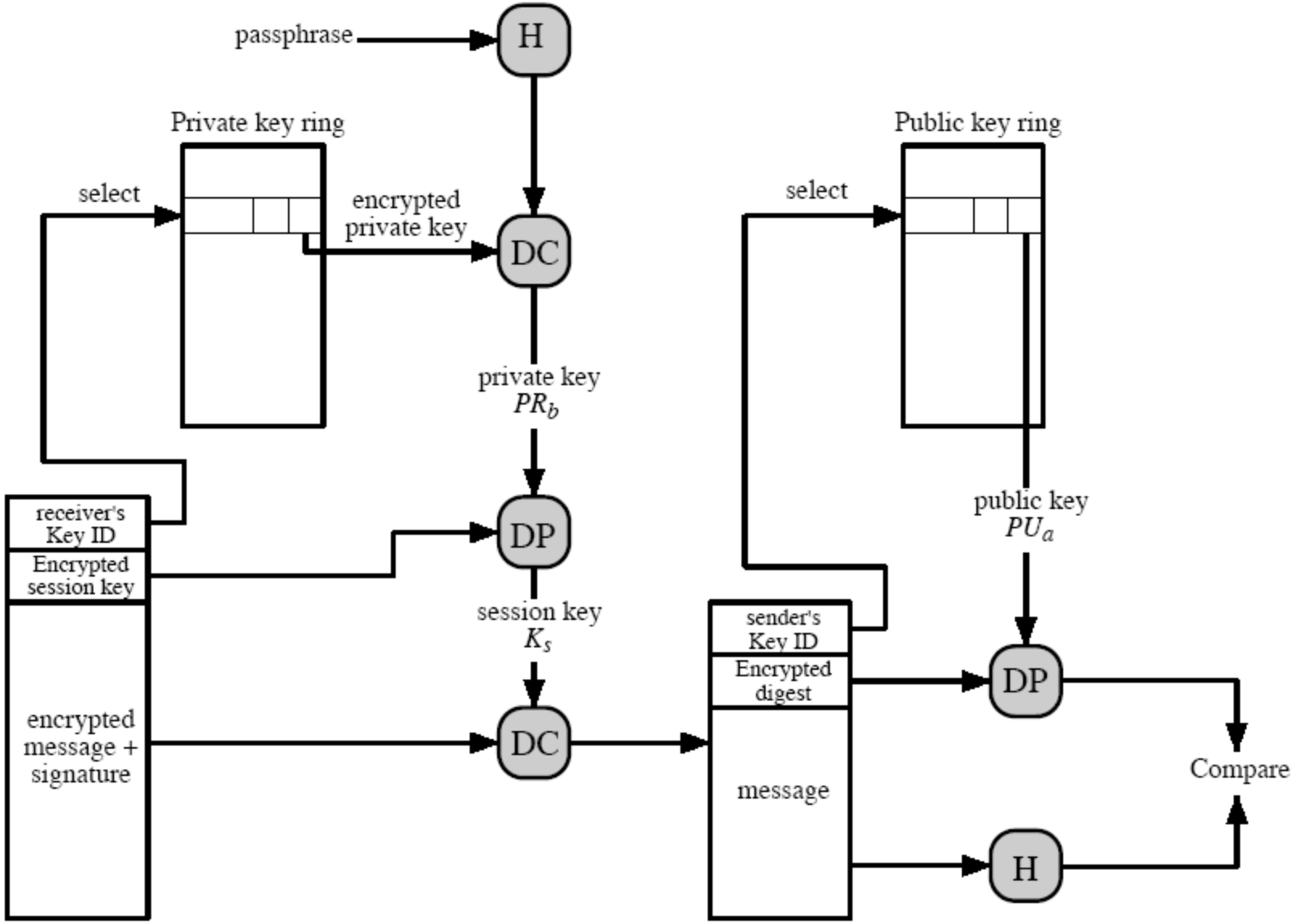
Timestamp	Key ID*	Public Key	Encrypted Private Key	User ID*
• • •	• • •	• • •	• • •	• • •
T_i	$PU_i \bmod 2^{64}$	PU_i	$E(H(P_i), PR_i)$	User i
• • •	• • •	• • •	• • •	• • •

* Key ID, Used ID combination uniquely identifies a key

Key rings and message generation



Key rings and message reception



Quick E-mail History

- SMTP and RFC 822 (later RFC 5322)
  - SMTP is the email transfer protocol running over TCP
  - RFC 822/5322 defines the message format and headers
    - only ASCII messages (7-bit)
- MIME (Multipurpose Internet Mail Extensions)
  - content type
    - Almost any type of information can appear in an email message
  - transfer encoding
    - specifies how the message body is encoded into textual form (radix64 is common)
- S/MIME: Secure MIME
  - new content types, like signature, encrypted data